PRIVACY IMPACT ASSESSMENT – A PRIMER

(Based on "Information privacy engineering and privacy by design", William Stallings, 2020)

Not to be shared publicly

Introduction

NIST SP 800-53 (Security and Privacy Controls for Information Systems and Organizations) defines a privacy impact assessment (PIA) as an analysis of how personally identifiable information is handled to ensure that handling conforms to applicable privacy requirements, determine the privacy risks associated with an information system or activity, and evaluate ways to mitigate privacy risks.

The GDPR mandates that a PIA include:

- A systematic description of the envisaged processing operations and the purposes of the processing, including, where applicable, the legitimate interest pursued by the controller
- An assessment of the necessity and proportionality of the processing operations in relation to the purposes
- An assessment of the risks to the rights and freedoms of data subjects
- The measures envisaged to address the risks, including safeguards, security measures, and mechanisms to ensure the protection of personal data and to demonstrate compliance with the GDPR, taking into account the rights and legitimate interests of data subjects and other persons concerned

Note that the term privacy impact assessment does not simply assess impact, but assesses privacy risk. Also, PIA is not limited to assessment but includes defining the controls for risk treatment.

The heart of the PIA process is privacy risk assessment. Figure 11.8 illustrates the process of determining privacy risk. The left-hand side of Figure 11.8 deals with determining privacy impacts. The analysis involves determining what PII is collected, processed, stored, and/or transmitted by the organization, as well as what data actions could constitute threats. The results of threats applied to PII are privacy impacts.

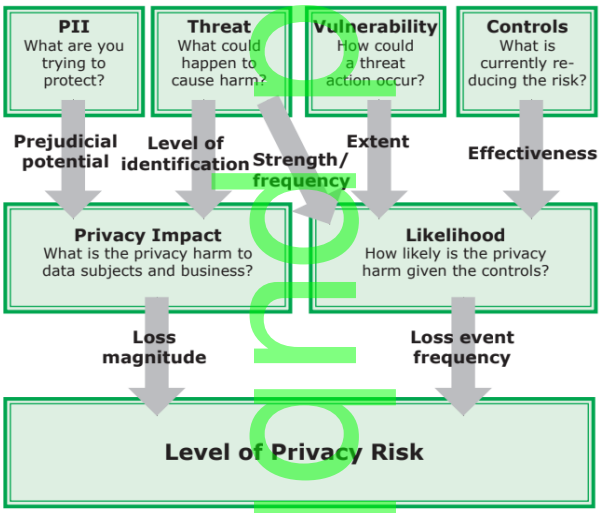


Figure 11.8 Determining Privacy Risk

not to be shared publicly

Privacy Impact

A typical approach to estimating privacy impact is to look at the two factors that contribute to the impact (refer to Figure 1):

- Prejudicial potential: An estimation of how much damage would be caused by all the potential consequences of a threat
- Level of identification: An estimation of how easy it is to identify data subjects with the available data processed by the available software

A typical approach to characterizing potential impacts is to use five levels, such as very low, low, moderate, high, and very high. An analyst could take into consideration to the type and amount of PII that is to be protected and the relevant threats that could violate the privacy of the PII principals (data subjects). Other factors include sensitivity of the PII breached, numbers of PII principals affected, and level of organizational impact. Table 11.3 provides examples of definitions, broken down into privacy harms to PII principals and costs to the organization.

Table 11.3 Definition of Privacy Impact Levels

Impact	Impact on PII principals	Impact on organization
Very low	Virtually no noticeable impact	Virtually no noticeable impact
Low	Negligible economic loss; or small, temporary reduction of reputation, or no impact on other personal factors	No violation of law or regulation; or negligible economic loss; or small, temporary reduction of reputation.
Moderate	Economic loss that can be restored; or small reduction of reputation or at most minor impact other personal factors	Minor violation of law or regulation resulting in warning; or economic loss which can be restored; or some reduction of reputation.
High	Large economic loss that cannot be restored; or serious loss of reputation or other psychological damage by revealing sensitive information; or serious impact on other personal factors.	Violation of law or regulation resulting in fine or minor penalty; or large economic loss that cannot be restored; or serious and long-lasting loss of reputation.
Very high	Considerable economic loss that cannot be restored; or serious loss of reputation or other psychological damage with long-lasting or permanent consequences; or serious impact on other personal factors.	Serious violation of law or regulation resulting in substantial fine or other penalty; or considerable economic loss that cannot be restored; or devastating and long-lasting loss of reputation.

Table 11.4 provides a breakdown of five levels of identification, with an example of each one. For a given threat category, a PIA analysis can estimate how easy is it to identify an individual should the threat gain access to the PII residing on an organization asset.

Table 11.4 Levels of Identification

Level	Definition	Example (large population database)
Very low (1)	Identifying an individual using their personal data appears to be virtually impossible.	Searching using only an individual's first name.
Low (2)	Identifying an individual using their personal data appears to be difficult but is possible in certain cases.	Searching using an individual's full name.
Moderate (3)	Identifying an individual using their personal data appears to be of only moderate difficulty.	Searching using an individual's full name and year of birth.
High (4)	Identifying an individual using their personal data appears to be relatively easy.	Searching using an individual's full name and date of birth.
Very high (5)	Identifying an individual using their personal data appears to be extremely easy.	Searching using an individual's full name, date of birth, and mailing address.

not for public

The following suggested methodology for combining prejudicial potential and level of identification is based on the document Data Protection Impact Assessment Template for Smart Grid and Smart Metering Systems from the E.U. Smart Grid Task Force [SGTF18]. The methodology includes the following steps:

1. Identify a list of privacy threat categories relevant to the organization's environment.
2. Identify the primary assets associated with each threat category. A primary asset is a set of one or more pieces of PII allocated on a specific IT system that requires protection.
3. For each primary asset, identify the relevant privacy harms that may occur.
4. For each potential harm resulting from a particular threat, associate the value of the level (1 = very low; up to 5 = very high) that best matches the prejudicial effect.
5. For each primary asset, determine the prejudicial effect as the maximum value of prejudicial effect for a potential harm.
6. For each primary asset of each threat category, take the sum of the level of identification and prejudicial effect and normalize to a scale of 1 to 5, using Table 11.5. The result is the privacy impact, or severity, for the primary asset.
7. The severity of a given threat category is the maximum value of severity for all associated primary assets.

Table 11.5 Privacy Impact Normalization Scale

Level of Identification + Prejudicial Effects	Impact or Severity
<4	Very low (1)
4 – 5	Low (2)
6	Moderate (3)
7	High (4)
>7	Very high (5)

Likelihood

NISTIR 8062 defines likelihood in privacy risk assessment as the estimated probability that a threat action will occur and be problematic for a representative or typical individual whose PII is processed by the system. This is a complex issue that involves assessing the following four factors (refer to Figure 11.8):

- The probability that a threat action will be attempted, either intentionally or unintentionally.
- The capability of the threat agent to perform the threat event.
- The vulnerabilities in the system that would enable the attempted threat action to occur.
- The reduction in probability due to the effectiveness of existing or planned security and privacy controls.

As with impact assessment, the risk analyst can use a five-level scale for each of these factors. The first two factors relate to the threat. Part a and b of Table 11.6 show typical definitions for threat capability and threat event frequency.

not for public sharing

Table 11.6 Privacy Likelihood Factors

(a) Capability of Threat Source

Level	Capability
Very low	Source has no special capabilities to carry out a threat.
Low	Source has limited capabilities to carry out a threat.
Moderate	Source has malicious intent and moderate capability to carry out a threat.
High	Source has malicious intent and unlimited administrative priviliges to carry out a threat.
Very high	Source has malicious intent and considerable expertise to carry out a threat.

(b) Threat Event Frequency

Level	Capability
Very low	< 0.1 times per year (less than once every 10 years)
Low	Between 0.1 and 1 times per year
Moderate	Between 1 and 10 times per year
High	Between 10 and 100 times per year
Very high	> 100 times per year

(c) Vulnerability

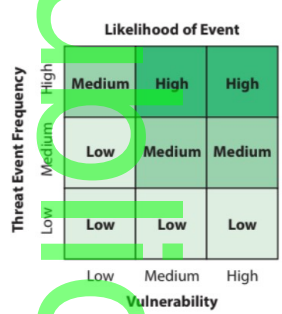
Level	Ease of privacy breach
Very low	Very difficult, requiring sustained effort and specialized expertise
Low	Cannot occur accidentally; or detailed knowledge of the system is needed; or requires help of authorized personnel
Moderate	Normal knowledge of the system is needed; or can be performed deliberately
High	Minor knowledge of the system is needed; or can be performed by wrong or careless usage.
Very high	No technical knowledge of the system is needed; or can be performed by wrong or careless usage.

(d) Control Effectiveness

Level	Capability
Very low	Only protects against bottom 2% of an average threat population
Low	Only protects against bottom 16% of an average threat population
Moderate	Protects against the average threat agent
High	Protects against all but the top 16% of an average threat population
Very high	Protects against all but the top 2% of an average threat population

Part c of Table 11.6 provides sample definitions for a five-level estimation of the extent of vulnerability, expressed in terms of the ease of privacy breach. However, an analyst needs to modify these estimates by considering any controls already designed or planned for the system that provide protection to the primary assets (PII data). The result of this analysis is a residual ease of privacy breach. Then the analyst could use a 5×5 matrix similar to the 3×3 matrix in part a of Figure 11.3. Finally, the analyst could use a matrix similar to part b of Figure 11.3 to estimate likelihood as a function of threat event frequency and the extent of vulnerability. As an alternative, the analyst could use the numerical equivalent of each level (very low = 1 and so on), take the sum of two factors, and then normalize using the same normalization as shown in Table 11.5. Thus, vulnerability is calculated by taking the normalized sum of threat capability and resistance strength. Then likelihood is calculated by taking the normalized sum of vulnerability and threat event frequency.

As with impact assessment, with privacy assessment, an analyst needs to perform the likelihood analysis for each primary asset for each threat category.



(b) Likelihood as a function of threat and vulnerability

Figure 11.3 Qualitative Risk Determination

Draft NIST Special Publication 800-122

Assessing Privacy Risk

Privacy risk assessment is based on an estimate of impact and of likelihood. An organization should carry out this assessment for each primary asset (PII stored on a system) and each threat category. The techniques used are essentially the same as those for information security risk assessment, described in Section 11.1.

For each primary asset and threat category, the organization should set a priority, based on where the risk is located in the matrix and on the risk criteria used by the organization. The following are typical guidelines for the five risk levels:

- **Very high**: These risks must be absolutely avoided or significantly reduced by implementing controls that reduce both their impact and likelihood. Recommend practice suggests that the organization implement independent controls of prevention (actions taken prior to a damaging event), protection (actions taken during a damaging event), and recovery (actions taken after a damaging event) [SGTF18].
- **High**: These risks should be avoided or reduced by implementing controls that reduce the impact and/or likelihood, as appropriate. For example, the matrix has a high-risk entry for a very high impact and low likelihood; in this case, the emphasis is on reducing impact. The emphasis for these risks should be on prevention if the impact is relatively high and the likelihood is relatively low and on recovery if the impact is relatively low and the likelihood is relatively high.
- **Moderate**: The approach for moderate risk is essentially the same as for high risk. The difference is that moderate risks are of lesser priority, and the organization may choose to devote fewer resources to addressing them.
- **Low**: The organization may be willing to accept these risks without further control implementation, especially if the treatment of other security or privacy risks also reduce this risk.
- **Very low**: The organization may be willing to accept these risks because further attempts at reduction would not be cost-effective.

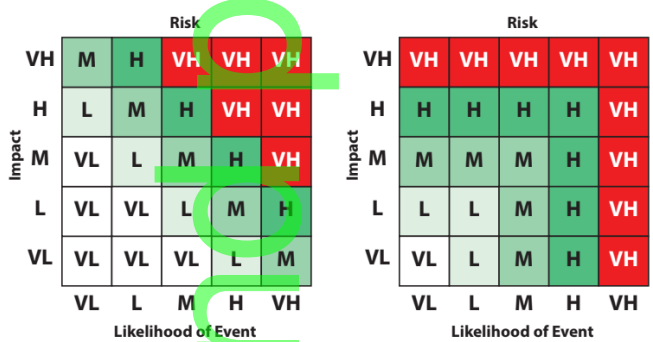


Figure 11.9 Two Example of Privacy Risk Matrices

not for publication

Privacy Impact Assessment

A PIA involves both privacy risk assessment and a plan for privacy risk treatment. ISO 29134 provides useful guidance in performing a PIA. Figure 11.10 summarizes the PIA process defined in ISO 29134. The two boxes on the lower left of the figure are not in fact part of the PIA process but provide context for how PIA fits into the overall privacy risk management scheme. This section examines the steps defined in the other boxes.

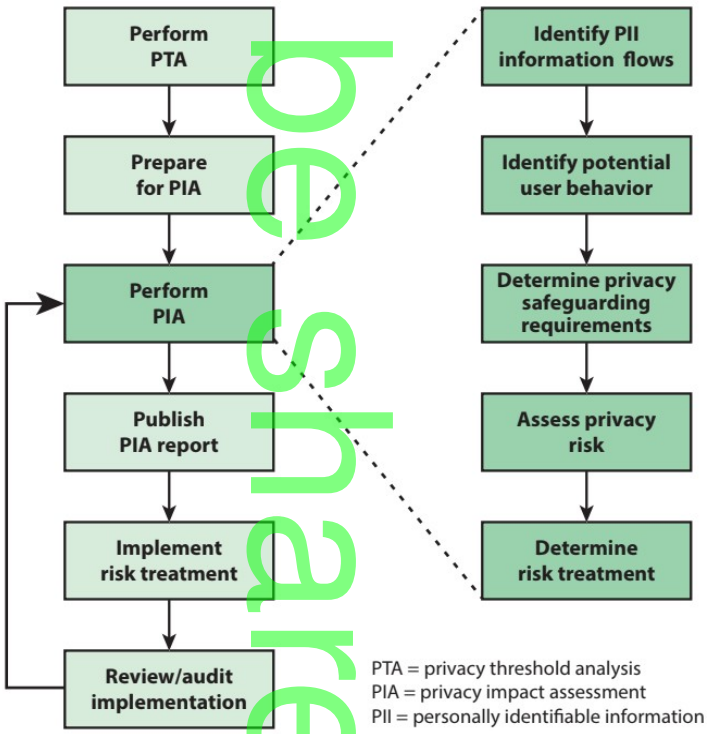


Figure 11.10 ISO 29134 PIA Process

Privacy Threshold Analysis (PTA)

A privacy threshold analysis (PTA) is a brief assessment that requires system owners to answer basic questions on the nature of their systems and whether the systems contain PII to identify systems that require PIA. This approach enables agencies to ensure that systems undergo the PIA process at the earliest stages of development.

A typical PTA includes the following information:

- Description of the system
- What PII, if any, is collected or used
- From whom the PII is collected

If no PII is collected or used, of if the PII is deemed to present no privacy risk, the PTA document would indicate no need for a PIA. Otherwise, the PTA document recommends a PIA. Typically, a

not publicly shared

privacy leader reviews the PTA to make a final decision about the need for a PIA.

Preparing for a PIA

Preparing for a PIA should be part of strategic security and privacy planning. The important components of PIA preparation are as follows:

- Identify the PIA team and provide it with direction. The privacy leader should have ultimate responsibility for the PIA. The privacy leader, together with other privacy personnel, should determine the scope of the PIA and the needed expertise. Depending on the size of the organization and the amount of PII involved, the team may need to include information security experts, a privacy counsel, operations managers, ethicists, business mission representatives, and others. The privacy leader or privacy team should define the risk criteria and ensure that senior management approve those criteria.
- Prepare a PIA plan. The person in charge of the PIA (the PIA assessor) should create a plan that specifies human resources, the business case, and a budget for conducting the PIA.
- Describe the system or project that is the subject of this PIA. This description should include an overview of the system or project, summarizing the system design, personnel involved, schedule, and budget. The description should focus on what PII is processed. The PII discussion should indicate what PII is collected/processed, the objectives, which PII principals are affected, what systems and processes are involved in the handling of PII, and what privacy policies govern the handling of the PII.
- Identify stakeholders. The assessor should indicate who is or might be interested in or affected by the project, technology, or service.

Identify PII Information Flows

Essential to understanding the privacy risks involved in the use of PII in a given system or project is a complete description of how PII flows into, through, and out of the system. A workflow diagram is a useful tool for ensuring that all aspects of PII handling are documented. Figure 11.11, from ISO 29134, is a typical example workflow of PII processing. An assessor should provide a commentary on and indicate the potential privacy impacts for each point in the workflow.

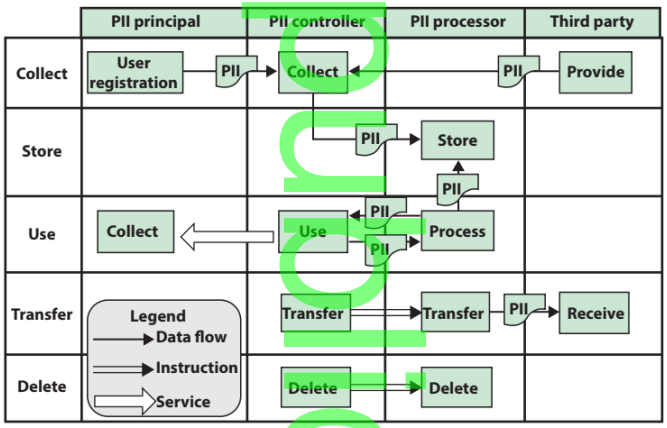


Figure 11.11 Workflow Diagram of PII Processing

not for publication

Determine Relevant Privacy Safeguarding Requirements

An assessor needs to determine which privacy safeguarding requirements are relevant to this system or process. These requirements can be grouped in the following areas:

- **Legal and regulatory**: Determine what laws and regulations apply to this case.
- **Contractual**: Determine what privacy safeguards are required by applicable contracts.
- **Business**: Determine what privacy safeguards that are a normal part of business operations apply. These include industry guidelines, best practices documents, and standards typically used in information security and privacy system design by the organization, and organizational privacy policies that apply to this case.
- **Individual**: Determine which FIPPs are relevant to this case.

These safeguarding requirements serve as a guide to what privacy controls need to be implemented.

Assess Privacy Risk

Privacy risk assessment has three steps:

- **Risk identification**: The assessor identifies the potential threats and the system vulnerabilities that are applicable to this case.
- **Risk analysis**: The assessor calculates the level of risk for each potential impact, as described in Section 11.4.
- **Risk evaluation**: The assessor determines the relative prioritization of privacy risk, based on the severity of privacy impact on PII principals as well as the overall impact to the organization.

Determine Risk Treatment

The final step of the PIA is to determine what risk treatments will be applied to the identified risks. This involves three tasks:

- Choose treatment options
- Determine controls
- Create risk treatment plans

Choose Treatment Options

Section 11.2 describes the risk treatment options risk reduction, risk retention, risk avoidance, and risk transfer. An assessor must recommend the most appropriate treatment option for each identified privacy risk. The treatment option decision for each risk involves balancing a number of factors, notably the cost of each option to the organization and the organization's obligation to protect the privacy of the PII.

Determine Controls

For each risk for which an assessor chooses risk reduction, the responsible privacy personnel need to select the appropriate combination of security and privacy controls to mitigate or eliminate the risk. The privacy leader may perform this task, or it may be assigned to one or more other privacy personnel, including the privacy assessor. The preference should be to use industry-standard controls,

Unpublished Draft

such as those defined in ISO 29151 (Code of Practice for Personally Identifiable Information Protection) and NIST SP 800-53.

Create Risk Treatment Plans

An assessor should develop a risk treatment plan for each identified risk that includes the following information:

- Rationale for the chosen treatment option
- Specific controls to be implemented
- Residual risk after treatment
- Result of a cost/benefit analysis
- Person responsible for implementation
- Schedule and resources
- How the implementation will be monitored and evaluated.

The PIA Report

The PIA report documents the PIA process. However, the PIA process is an ongoing activity, as indicated by the return loop in Figure 11.10. New information may lead to a return to the PIA process, which in turn results in an updated PIA report. Objectives for the PIA report include:

- Demonstrate that the PIA process was performed in accordance with the organization's policy.
- Provide a basis for post-implementation review.
- Provide input to an information privacy audit.
- Provide a documented basis if iterations of the PIA process for this project are necessary.

Based on a review of numerous examples of PIA reports from Australia, Canada, New Zealand, the United Kingdom, and the United States, the PIAFProject [PIAF11] recommends that the PIA report should:

- Clarify whether the PIA was initiated early enough so that there was still time to influence the outcome
- Indicate who conducted the PIA
- Include a description of the project to be assessed, its purpose, and any relevant contextual information
- Map the information flows (i.e., how information is collected, used, stored, secured, and distributed and to whom and how long the data is retained)
- Check the project's compliance against relevant legislation
- Identify the risks to or impacts on privacy
- Identify solutions or options for avoiding or mitigating the risks
- Make recommendations
- Be published on the organization's website and be easily found there or, if the PIA report is not published (even in a redacted form), there should be an explanation as to why it has not been published
- Identify what consultation and with which stakeholders was undertaken

The PIAFProject report [PIAF11] contains a number of examples of PIA reports that can be useful guides for an organization designing its own report format.

not to be republished

Implement Risk Treatment
Once the PIA report has been approved by senior management, the individual or team responsible for privacy risk treatment can implement the controls that have been approved. Prior to implementation, the organization should provide the appropriate training for developers and users to ensure that privacy implications are fully considered.

Review/Audit Implementation
The organization should designate an individual or a group to assess the operational effectiveness of the privacy risk treatment implementation. Chapter 13, "Event Monitoring, Auditing, and Incident Response," addresses this topic. When it is determined that there are inadequacies or new requirements, the organization should mandate a new or updated PIA.

Examples of real-world PIAs

- *Privacy Impact Assessment for the Integrated Data Infrastructure* from Statistics New Zealand [SNZ12]
- *Data Protection Impact Assessment Template for Smart Grid and Smart Metering Systems* from E.U. Smart Grid Task Force [SGTF18]

Guidelines, tools & software for PIAs

https://www.cnil.fr/en/privacy-impact-assessment-pia
https://www.cnil.fr/en/open-source-pia-software-helps-carry-out-data-protection-impact-assesment
https://www.enisa.europa.eu/risk-level-tool/risk
(more focused on security risk assessment in the context of personal data processing operations)

References

[SNZ12] Statistics New Zealand. *Privacy Impact Assessment for the Integrated Data Infrastructure*. 2012. https://www.stats.govt.nz/assets/Uploads/Retirement-of-archive-website-project-files/Privacy-Impact-Assessment/Privacy-impact-assessment-for-the-Integrated-Data-Infrastructure/idi-privacy-impact-assessment.pdf
[SGTF18] E.U. Smart Grid Task Force. *Data Protection Impact Assessment Template for Smart Grid and Smart Metering Systems*. September 2018. https://ec.europa.eu/energy/content/data-protection-impact-assessment-template-smart-grid-and-smart-metering-systems_en
[PIAF11] PIAFProject. *A Privacy Impact Assessment Framework for Data Protection and Privacy Rights*. Prepared for the Eurpean Commissiom Directorate General Justice. 21 September 2011. https://piafproject.wordpress.com/

not for public release